

PROPUESTA TÉCNICA / ARQUITECTURA DE INTEGRACIÓN

Arquitectura de integración bancaria

Convivencia multicore y modernización progresiva

Una propuesta para integrar canales digitales, pagos, Open Finance, riesgos y prevención de fraude, con propiedad de datos y recuperación explícitas.

C4	2 cores	10 tareas
----	---------	-----------

01. Resumen ejecutivo

Se propone una plataforma de integración que ofrece contratos estables a banca web, móvil y terceros, mientras mantiene un core tradicional y un core digital. La migración se realiza por cohortes de cuentas. Cada cuenta tiene un único core autorizado para registrar movimientos en cada instante; un directorio versionado resuelve su ubicación.

El dominio de Pagos conserva la orden y coordina su ejecución. Los cores conservan saldos y asientos. Los adaptadores aíslan protocolos y semántica de cada proveedor. Una plataforma de eventos distribuye hechos confirmados hacia riesgos, proyecciones de consulta y auditoría. La prevención de fraude interviene antes de cualquier cargo, aunque la recepción de la orden sea asíncrona.

Decisiones que sostienen la solución

- Contratos por capacidad bancaria. Cuentas, Pagos y Autorización tienen responsabilidades y propietarios definidos. La relación con BIAN 14 se documenta como alineación semántica, sin afirmar certificación.
- Un escritor por cuenta. El core digital no funciona como respaldo del tradicional. Cada uno tiene su propia recuperación técnica; la migración cambia la autoridad mediante un procedimiento controlado.
- Operaciones monetarias verificables. Se conservan identificadores estables por orden y por paso, estado durable y evidencia de contabilización. Una interrupción no equivale a un rechazo.
- Comunicación mixta. Las consultas y decisiones inmediatas utilizan APIs. Los hechos de negocio se distribuyen mediante eventos, con consumidores idempotentes y conciliación.
- Seguridad aplicada en cada límite. La identidad se valida al ingresar; los servicios autorizan el recurso y la operación; adaptadores y cores aplican controles de ejecución.
- Migración condicionada por evidencias. Una cohorte avanza solamente después de conciliar datos, demostrar ausencia de doble escritura y probar recuperación.

Lectura del documento

Las secciones 03 a 07 contienen las vistas C4. Las secciones 08 a 14 desarrollan datos, operaciones y contratos. Las secciones 15 a 21 explican seguridad, continuidad, migración y operación. La sección 22 relaciona cada tarea del ejercicio con su evidencia.

Resultado esperado

Los canales conservan una interfaz consistente durante la transición. El banco puede incorporar productos al core digital sin trasladar a los canales la lógica de coexistencia. Los casos incompletos quedan identificados, conciliables y bajo responsabilidad operativa.

02. Alcance, supuestos y objetivos

Se cubren consultas de cuentas, transferencias internas y entre cores, integración con una plataforma de pagos externos, acceso de terceros, antifraude y alimentación de riesgos. El diseño no sustituye la contabilidad ni implementa motores de riesgo o fraude.

Supuesto	Decisión y validación necesaria
Jurisdicción no especificada	Ecuador, acordado como supuesto. Cumplimiento valida las normas aplicables al banco y al producto antes de producción.
Interfaces del core desconocidas	Se presupone consulta por referencia de operación y algún mecanismo de deduplicación o ejecución controlada. Sin esta capacidad no se automatizan reenvíos monetarios inciertos.
Datos maestros de clientes	El core tradicional conserva inicialmente la identidad bancaria y el expediente del cliente. El core digital usa referencias vinculadas; el IdP conserva credenciales, no el expediente financiero.
Productos iniciales	Cuentas transaccionales y transferencias en USD. Divisas, tarjetas y pagos programados requieren ampliaciones de reglas y contratos.
Infraestructura	Sitio principal con tres dominios de fallo, sitio alternativo y tercera ubicación para réplica crítica. La nube requiere evaluar latencia y condiciones contractuales.
Operación heredada	Se inventarían sucursales, ATM, lotes y procesos nocturnos. También deben respetar la autoridad de escritura por cuenta.

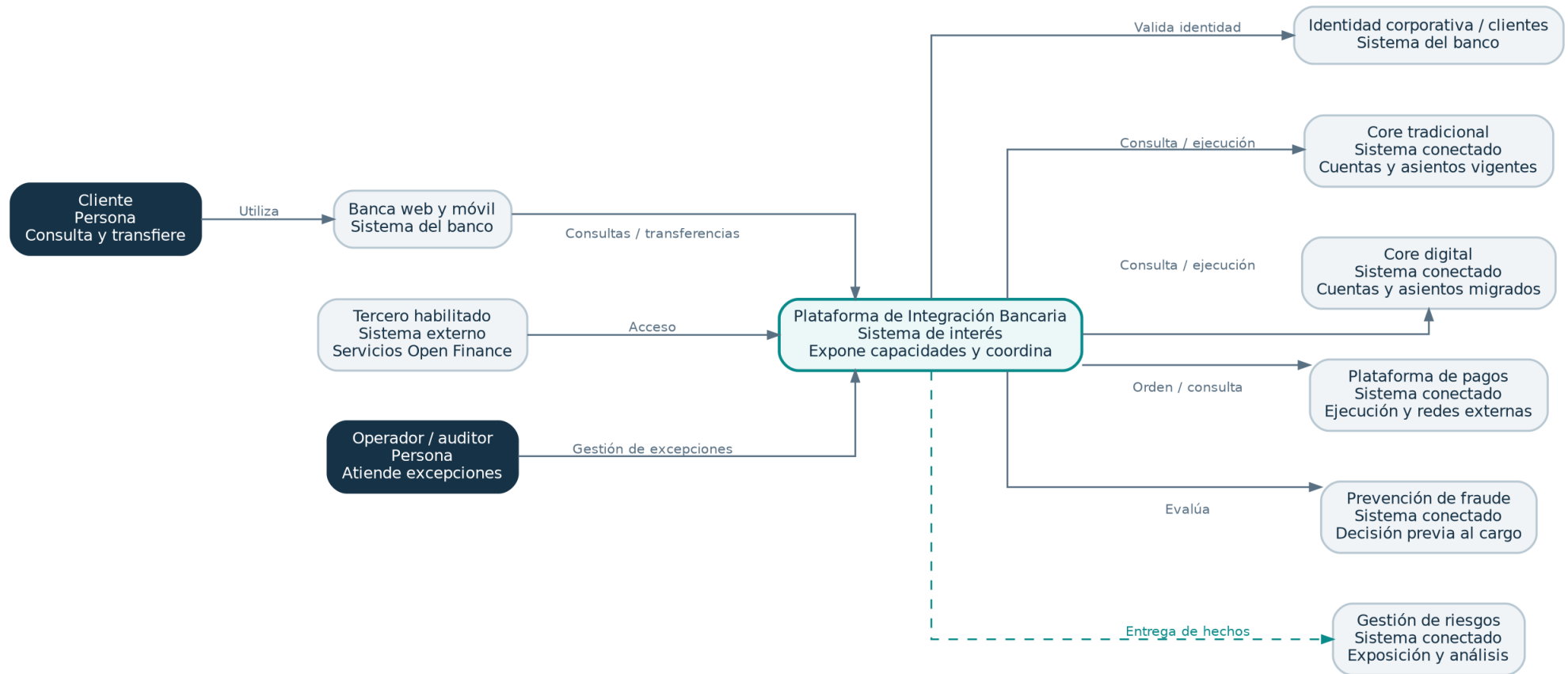
Objetivos no funcionales propuestos

Indicador	Objetivo de diseño	Cómo se verifica
Disponibilidad de servicios críticos	99,99% mensual, incluyendo dependencias	Sondas de recorrido completo y errores técnicos; rechazos comerciales válidos se distinguen de fallas.
Consulta de saldo	$p_{95} \leq 500 \text{ ms}$; $p_{99} \leq 1 \text{ s}$	Desde ingreso al banco hasta respuesta del core; red del cliente se mide por separado.
Recepción de orden	$p_{95} \leq 700 \text{ ms}$ para aceptación durable	Incluye autorización de acceso y persistencia; no implica transferencia completada.

Indicador	Objetivo de diseño	Cómo se verifica
Transferencia interna automática	p95 $\leq$ 3 s en condiciones normales	Desde recepción hasta asientos confirmados; revisión manual se reporta aparte.
Capacidad inicial	300 órdenes/s y 1.500 consultas/s; ráfaga 2x	Hipótesis de dimensionamiento, a reemplazar por volumetría real.
Proyecciones de lectura	Frescura p95 $\leq$ 5 s	Se expone fecha de actualización; el saldo disponible para debitar se decide en el core.

03. C4 nivel 1: contexto del sistema

El sistema de interés es la Plataforma de Integración Bancaria. Los canales y las aplicaciones bancarias conectadas se muestran como sistemas externos a ese límite, aunque pertenezcan al mismo banco. C4 separa contexto, contenedores y componentes; aquí se utilizan esos tres niveles.

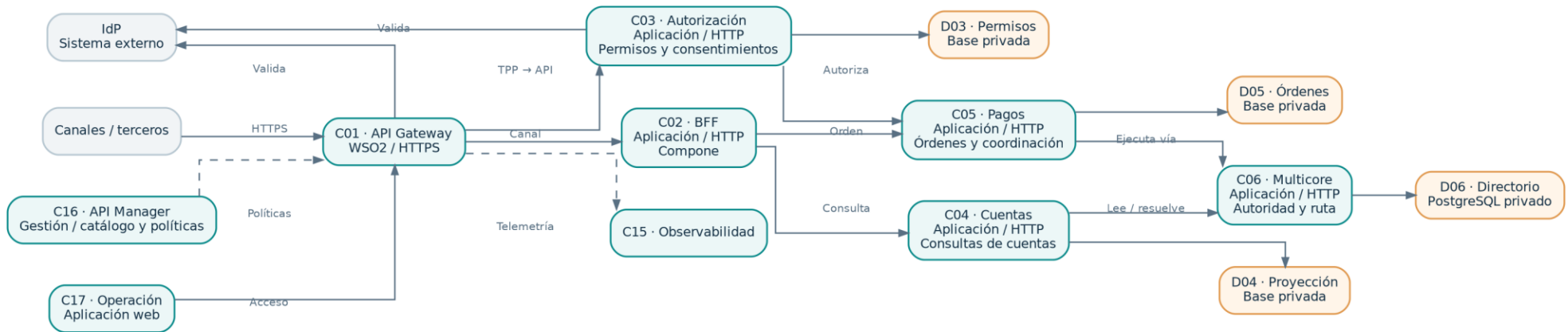


Lectura: flecha continua = interacción; discontinua verde = entrega de hechos. Los sistemas grises están fuera del sistema de interés.

Los clientes utilizan los canales. Los terceros se conectan con autorización del titular y credenciales propias. Los operadores consultan y resuelven excepciones con permisos específicos. Riesgos recibe hechos transaccionales; el antifraude ofrece decisiones previas a la ejecución. El IdP corporativo y de clientes suministra identidad federada.

04. C4 nivel 2: acceso y servicios de negocio

Primera vista de contenedores del mismo sistema. Los identificadores C01 a C17 se mantienen en las vistas siguientes. Un contenedor C4 representa una aplicación o almacenamiento ejecutable; no implica por sí mismo un contenedor Docker.

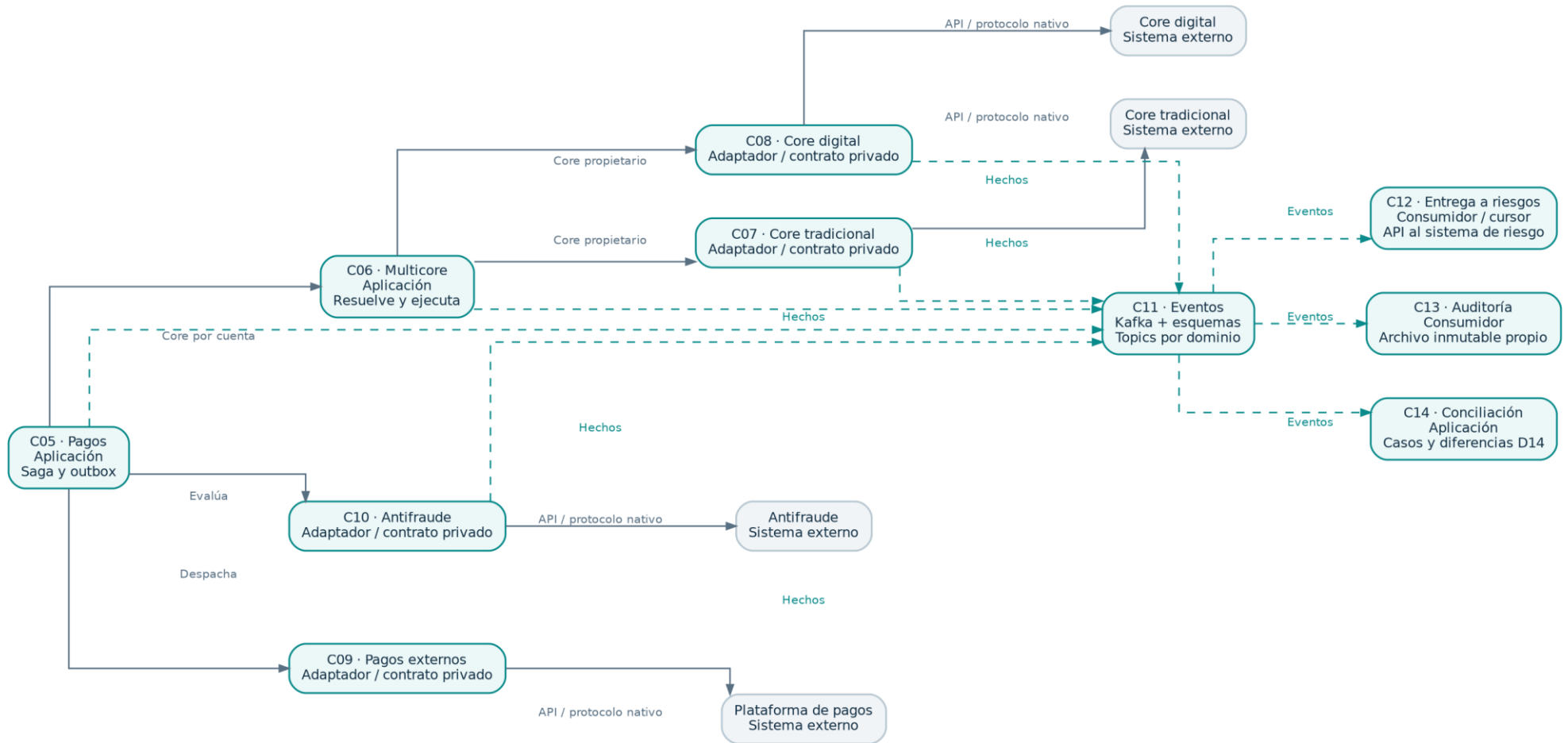


* La validación del IdP es transversal a C01/C03 y servicios. D03/D04/D05/D06 solo son accesibles a su propietario. Continuación: vista 05.

El API Manager mantiene catálogo, políticas y portal; C01 ejecuta el tráfico. C02 adapta respuestas a los canales. C03 aplica permisos por cuenta y consentimientos. C04 administra consultas de cuentas. C05 conserva órdenes y coordina pagos. C06 resuelve el core y hace cumplir la autoridad de escritura. Las bases se presentan individualmente por propietario; no existe acceso SQL entre servicios.

05. C4 nivel 2: integración y eventos

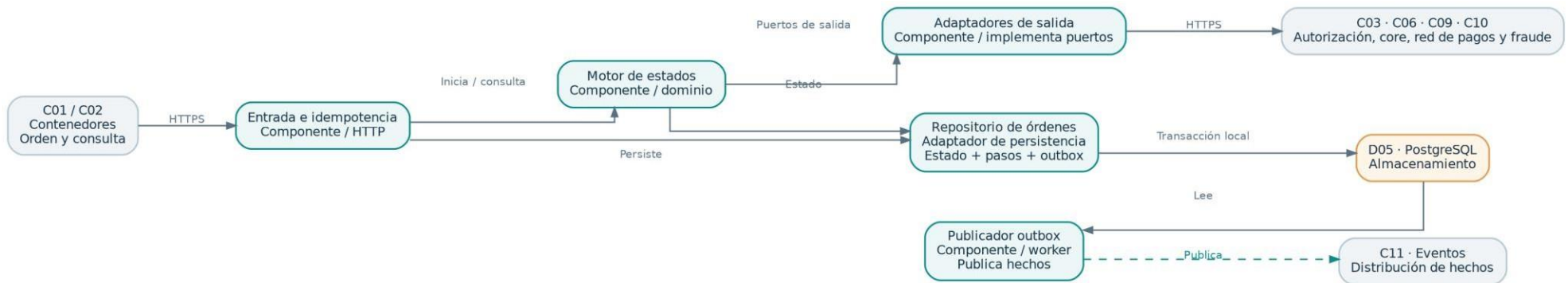
Segunda vista de contenedores. C05 y C06 son los mismos servicios de la vista anterior. Esta ampliación expone adaptadores y consumidores, sin crear una segunda plataforma.



C07 y C08 traducen contratos y errores de cada core. C09 aísla la plataforma de pagos externos. C10 aísla el antifraude. C11 conserva y distribuye eventos; su registro de esquemas es parte de la plataforma de mensajería. C12 entrega eventos a riesgos, mantiene su cursor y evita duplicados. C13 guarda auditoría de negocio con acceso restringido. C14 registra discrepancias y solicita a Pagos una resolución autorizada; no altera saldos directamente.

06. C4 nivel 3: componentes de Pagos

Se amplía exclusivamente C05. Sus componentes comparten el despliegue y la base privada D05. Las llamadas hacia C03, C06, C09, C10 y C11 atraviesan contratos explícitos.



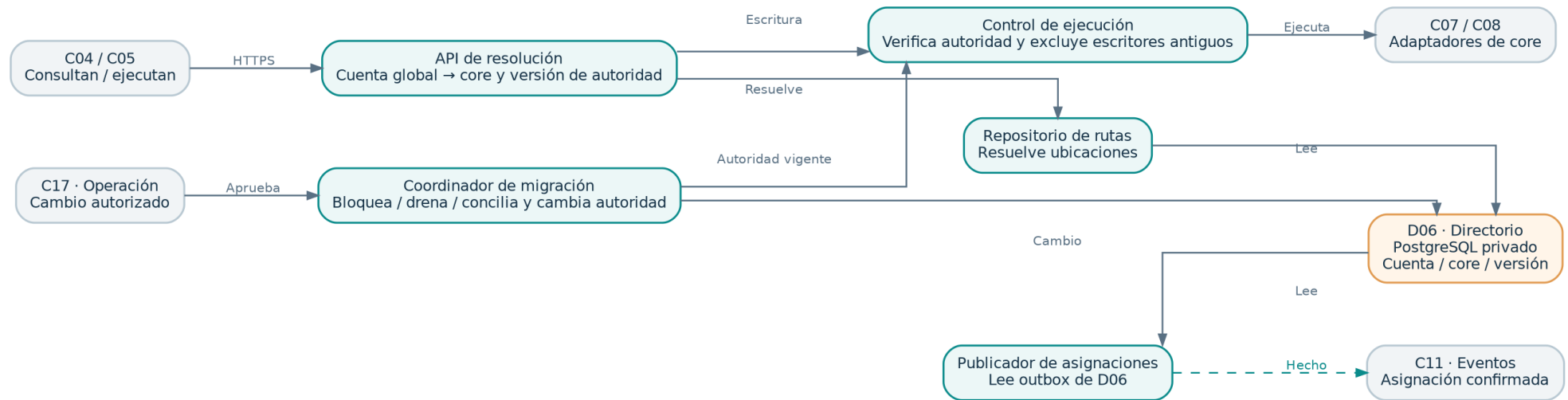
Dependencias de código hacia los puertos; adaptadores hacia sistemas externos. D05 no comparte tablas con otros servicios.

La entrada valida el formato y la idempotencia; el motor de estados coordina el ciclo de vida. Los puertos de salida representan capacidades requeridas por el dominio. Las implementaciones de esos puertos invocan los contenedores externos. El repositorio registra estado, pasos, respuestas y mensajes pendientes de publicación en una transacción local. Un publicador separado dentro de C05 drena el outbox.

La ejecución se serializa por orden mediante versión de estado y exclusión de trabajo. Dos procesos pueden recibir la misma tarea, pero solo uno obtiene la transición válida. El adaptador de persistencia puede cambiar sin modificar las reglas del pago; las reglas se prueban sustituyendo los puertos por dobles controlados.

07. C4 nivel 3: directorio y control multicore

Se amplía exclusivamente C06. El directorio almacena identificador global de cuenta, identificador local, core propietario, estado migratorio y versión de autoridad. No almacena el saldo disponible.



D06 conserva metadatos, nunca saldos. La migración bloquea todas las rutas de escritura, incluidos lotes y canales heredados.

Una orden registra la versión de autoridad utilizada. Antes de cada escritura, el control de ejecución valida que siga vigente. El cambio de propietario exige bloquear nuevas escrituras de la cohorte, agotar tareas en curso y cerrar las rutas heredadas. Los tokens de exclusión ayudan a detener procesos antiguos; el control efectivo también debe alcanzar el core, sus adaptadores y los canales directos.

Una caché sirve metadatos de lectura. Las escrituras requieren autoridad vigente; si no puede verificarse, se detienen. No se selecciona el otro core por disponibilidad. Para una transferencia entre cores se conservan ambas ubicaciones y se impide migrar cualquiera de las cuentas mientras tenga pasos monetarios abiertos.

08. Dominios, BIAN y propiedad de datos

Se toma BIAN 14 como referencia semántica. Sus notas marcan Payment Order y Payment Execution como obsoletos y documentan el cambio a Payment Order Initiation y Payment Rail para otros dominios relacionados. Por ello no se presenta un catálogo anterior como si fuera el actual.

Payment Order Initiation aporta la captura e inicio de una instrucción de pago. Fraud Evaluation aporta evaluación de patrones de fraude. El mapeo siguiente es una selección de responsabilidades del diseño; no equivale a implementar íntegramente cada dominio BIAN ni a asignar un microservicio por dominio BIAN.

Capacidad y referencia	Propietario en la propuesta	Registro oficial y límite
Cuentas / Current Account	Equipo Cuentas; C04 como fachada	El core propietario conserva contrato de cuenta, saldo y asientos. C04 mantiene solamente una proyección derivada.
Inicio de pagos / Payment Order Initiation	Equipo Pagos; entrada de C05	D05 conserva instrucción, autorización capturada, estado y referencias. Nunca sustituye el libro mayor.
Orquestación de pagos / Payment Orchestration	Equipo Pagos; motor de C05	D05 conserva la secuencia de pasos y sus resultados. La agrupación con iniciación es una decisión de despliegue inicial.
Conexión con redes / Payment Rail	Equipo Integración de pagos; C09	La plataforma externa conserva su ejecución y liquidación. C09 conserva correlación técnica y acuses.
Evaluación / Fraud Evaluation	Equipo Fraude; sistema externo y C10	El motor conserva evaluación, versión de reglas y resultado. Pagos conserva su referencia y decisión aplicada.
Permisos / Customer Access Entitlement	Equipo Identidad y acceso; C03	D03 conserva derechos por recurso y consentimientos. El IdP es responsable de credenciales y sesiones.
Riesgo empresarial	Equipo Riesgos; sistema externo y C12	El sistema de riesgos conserva exposición, modelos y resultados. Recibe eventos con finalidad definida.
Ubicación de cuentas	Equipo Plataforma core; C06	D06 es la autoridad de enrutamiento. Es una capacidad técnica local, sin equivalencia BIAN forzada.

Reglas de gobierno de datos

Las referencias globales enlazan cuentas y clientes sin copiar expedientes completos. Cada equipo publica cambios mediante contratos; ningún consumidor modifica la base de otro. Las discrepancias generan casos en D14.

Cualquier rectificación monetaria se ejecuta mediante una operación del core autorizada y auditable.

Las proyecciones pueden reconstruirse desde una instantánea y eventos posteriores. Los eventos, la base de órdenes y los registros no son fuentes intercambiables de contabilidad. La política de retención se define por categoría de dato, finalidad y obligación aplicable.

09. Flujo de transferencia entre cores

Caso de referencia: una persona transfiere USD 125,50 de una cuenta del core tradicional a otra del core digital. Los identificadores usados en esta propuesta son ficticios.

Paso	Acción y evidencia
1.	C01 verifica el token. C05 verifica estructura, clave idempotente y permisos con C03. Misma clave y mismo contenido devuelven la misma orden; contenido distinto produce conflicto.
2. Recepción	C05 persiste orden y trabajo pendiente antes de responder 202 con paymentId y URL de consulta. El estado RECEIVED significa recibida, no autorizada financieramente ni completada.
3.	C05 consulta a C10. Un rechazo de fraude termina sin cargo. Un reto adicional produce AWAITING_AUTHORIZATION. Un timeout produce PENDING_REVIEW con vencimiento.
4. Preparación	Se resuelven ambas cuentas en C06, se fijan versiones y se validan permisos transaccionales vigentes. El core origen evalúa saldo disponible y límites monetarios atómicamente.
5.	C07 solicita contabilizar en origen con referencia paymentId/debit. El core registra el cargo y su contrapartida en cuenta puente dentro de su transacción local. Se guarda la referencia de asiento.
6. Abono	C08 solicita el abono con referencia paymentId/credit. El core destino registra beneficiario y contrapartida de enlace en su propia transacción local.
7.	Solo tras verificar ambos asientos C05 transita a COMPLETED y registra PaymentCompleted en su outbox. El comprobante incluye referencias, importe, moneda y fecha.

Paso	Acción y evidencia
8. Seguimiento	C11 distribuye el hecho a riesgos, auditoría, conciliación y vistas de lectura. Cada consumidor registra eventId y resultado en su almacenamiento privado.

Estados y consistencia

RECEIVED pasa a EVALUATING y, cuando procede, a AUTHORIZED, DEBIT_CONFIRMED, CREDIT_CONFIRMED y

COMPLETED. REJECTED corresponde a una negativa definitiva anterior al cargo.

PENDING_REVIEW y AWAITING_AUTHORIZATION no permiten contabilizar. Un paso sin resultado verificable produce UNKNOWN y bloquea la siguiente acción monetaria.

Si existe cargo y el abono es rechazado definitivamente, se inicia REVERSAL_PENDING. Solo una reversión confirmada permite REVERSED. No se borra el cargo original. Si ambos asientos ya existen, una devolución posterior constituye otra operación, con sus propias reglas.

La coordinación entre cores es una saga durable con cuentas puente conciliables; no se promete una transacción ACID distribuida. El core mantiene la integridad local y el servicio de Pagos hace visible la inconsistencia temporal hasta resolverla. Contabilidad aprueba las cuentas puente y su tratamiento antes de operar.

Para cuentas del mismo core se utiliza su transferencia atómica nativa, si existe. Para pagos externos, C09 conserva la referencia de red y distingue recepción, aceptación y liquidación; un acuse de transporte no permite declarar el pago liquidado. Devoluciones y rechazos posteriores se registran como hechos separados.

10. Fallos, decisiones y conciliación

Situación	Comportamiento obligatorio del diseño	Responsable y evidencia
El core debitó y se perdió la respuesta	Consultar por referencia estable. Mantener UNKNOWN hasta conocer el resultado; no generar un cargo con otra referencia.	Pagos + Core: registro del intento y consulta al asiento.
Destino inaccesible después del cargo	Conservar cargo y estado pendiente. Reintentar solo con deduplicación demostrada; abrir caso por antigüedad.	Pagos + Operaciones: exposición de cuenta puente.
Abono rechazado definitivamente	Ejecutar reversión contable en origen si la regla de negocio lo permite. No compensar por un simple timeout.	Operaciones / Contabilidad: referencia de reversión.

Situación	Comportamiento obligatorio del diseño	Responsable y evidencia
Core sin deduplicación ni búsqueda fiable	Detener automatización de casos inciertos; conciliación y resolución manual. Es una condición que impide activar esa cohorte automáticamente.	Dueño del core: prueba de capacidad o limitación registrada.
Antifraude sin respuesta	Antes del cargo, poner en revisión. Propuesta: 300 ms por consulta y 2 minutos de vigencia de la evaluación pendiente; vencimiento sin cargo produce rechazo técnico.	Fraude: decisión con versión y política de contingencia aprobada.
Riesgos analíticos no disponible	Mantener eventos y cursor de entrega. El pago no depende del reporte posterior. Si una regla de riesgo es previa, pasa a formar parte de la autorización obligatoria.	Riesgos + Integración: retraso y reproceso controlado.
Broker no disponible	Los hechos quedan en outbox. La recepción continúa solo mientras exista capacidad y antigüedad tolerable; se aplica contrapresión al superar umbrales.	Plataforma: edad del outbox y almacenamiento libre.
Directorio o autorización no verificables	Bloquear escrituras nuevas. Las consultas pueden degradarse mostrando antigüedad, sin presentar caché como saldo actual.	Plataforma core / Identidad: motivo y alcance del bloqueo.

Conciliación operativa

C14 contrasta órdenes y pasos de D05, referencias de C07/C08/C09 y asientos obtenidos por interfaces de consulta o extractos controlados. No accede directamente a las tablas privadas. Agrupa por paymentId, referencia local, importe, moneda y fecha contable. La misma orden puede tener varios intentos técnicos, pero cada paso conserva una única referencia monetaria.

Se propone seguimiento continuo y cierre diario por totales y detalle. Un pendiente monetario de más de 60 segundos genera alerta; a los 5 minutos se asigna un caso a Operaciones. Son umbrales operativos propuestos. La reparación exige evidencia y doble aprobación cuando implique un movimiento de fondos. No se autoriza un reenvío masivo desde una cola de errores.

11. Estrategia de APIs y contratos

Las APIs HTTP se describen con OpenAPI 3.1.1 como línea base elegida. Los contratos separan acceso de terceros y operación interna. El API Gateway valida transporte, autenticación inicial, cuotas y formato; el servicio propietario conserva reglas, permisos por objeto y decisiones monetarias.

Interfaz de referencia	Propietario y acceso	Respuesta y semántica
GET /v1/accounts	C04; accounts:read y cuentas permitidas	Lista paginada con identificador global y productos visibles.
GET /v1/accounts/{id}/balances	C04; balances:read y autorización sobre ids	Saldo desde core, moneda y asOf. Datos derivados se identifican expresamente.
POST /v1/payments	C05; payments:write; Idempotency-Key	202 y paymentId cuando la recepción es durable. 409 si la clave se reutiliza con otro contenido.
GET /v1/payments/{id}	C05; permiso sobre la orden	Estado, fecha, referencias y motivo público. No expone reglas sensibles de fraude.
POST /v1/consents	C03; cliente o tercero habilitado	Consentimiento pendiente; activación requiere aprobación autenticada del titular.
POST /v1/consents/{id}/revoke	C03; titular o actor autorizado	Revocación idempotente y nueva versión. Impide usos posteriores según el punto de autorización definido.
Consulta/ejecución de core	C06, C07 y C08; identidad de proceso	Interfaces privadas separadas: consultar, contabilizar y verificar resultado.

Ejemplo descriptivo de orden

Campos mínimos: debtorAccountId, creditorAccountId o beneficiario externo, amountDecimal, currency, clientReference y, para terceros, consentId. El importe se representa como decimal exacto y moneda ISO; no como punto flotante. C05 deriva el sujeto autenticado del token y los permisos, nunca de un customerId libre enviado por el cliente.

La clave idempotente se acota a cliente técnico, sujeto y operación. Se conserva durante 30 días como objetivo inicial; después de ese plazo el consumidor debe consultar por referencia antes de reenviar. La referencia monetaria persiste durante toda la retención contable aplicable. Las respuestas técnicas no garantizan por sí mismas la finalización de un pago.

Evolución e interoperabilidad

Los cambios compatibles añaden campos opcionales. Cambios de significado, obligatoriedad o estructura requieren nueva versión mayor y coexistencia acordada. Errores incluyen código estable, mensaje público y correlationId, sin datos internos. La mensajería de la red de pagos se mapea a su perfil ISO 20022 cuando corresponda; adoptar ISO 20022 no implica que cada API interna deba transportar XML.

12. Catálogo de eventos de negocio

AsyncAPI 3.0.0 se adopta como línea base documental para canales, mensajes, productores y consumidores. CloudEvents 1.0 aporta un sobre interoperable. Las versiones elegidas se fijan en gobierno, sin afirmar que sean las únicas o más recientes disponibles.

Evento y productor	Consumidores autorizados	Datos de negocio y finalidad
PaymentReceived.v1 / C05	C13 Auditoría	paymentId, instante, canal y referencia de actor. Evidencia de recepción, no de cargo.
PaymentCompleted.v1 / C05	C12 Riesgos, C13 Auditoría, C14 Conciliación	paymentId, importe, moneda, referencias de ambos pasos y completedAt. Solo se emite tras resultados confirmados.
PaymentReversed.v1 / C05	Riesgos, Auditoría, Conciliación	Orden original, referencia de reversión y motivo clasificado. Mantiene vínculo con el movimiento compensado.
AccountPostingRecorded.v1 / C07 o C08	C04 Proyección, C14 Conciliación	Cuenta, referencia del asiento, core, secuencia y fecha. Se origina en evidencia confirmada del core.
FraudDecisionRecorded.v1 / C10	C05 Pagos, C13 Auditoría restringida	assessmentId, paymentId, allow/deny/challenge, versión y vencimiento. No difunde variables sensibles del modelo.
ConsentRevoked.v1 / C03	C01 invalidación de caché, C13 Auditoría	consentId, nueva versión e instante. La seguridad no depende únicamente de recibir este evento.
AccountCoreAssigned.v1 / C06	C04 caché de lectura, C13 Auditoría, C14	Cuenta, core previo/nuevo, versión, instante y migrationBatchId. No autoriza escrituras con datos antiguos.

Del evento al efecto

Cada hecho tiene un productor responsable. Los eventos describen algo ocurrido y no ordenan ejecutar cargos. Un proceso de Pagos reanuda pasos desde el estado durable de C05; ningún consumidor de PaymentCompleted vuelve a contabilizar el pago.

C07 y C08 convierten notificaciones fiables o consultas incrementales de asientos en eventos normalizados. Si se utiliza captura de cambios, debe estar autorizada, ser de solo lectura y conservar el vínculo con el asiento. No se interpreta cualquier cambio de fila como un hecho de negocio. Las brechas de secuencia se resuelven contra la fuente.

La proyección aplica AccountPostingRecorded por cuenta; no aplica además PaymentCompleted al saldo, lo que duplicaría el efecto. Los consumidores de riesgos pueden utilizar ambos tipos para finalidades distintas, deduplicando y correlacionando explícitamente.

13. Fiabilidad de eventos y ejemplo de contenido

Campo de referencia	Valor ilustrativo o regla
specversion / id	1.0 / identificador único del evento; estable durante reenvíos.
source / type	urn:banco:pagos / ec.banco.payment.completed.v1.
subject / time	payments/PAY-DEMO-001 / fecha de confirmación en UTC.
datacontenttype / dataschema	application/json / referencia versionada del esquema en el registro.
traceparent / correlationid	Contexto técnico y vínculo con la orden; sin credenciales.
paymentId / amountDecimal / currency	PAY-DEMO-001 / 125.50 / USD.
debtorAccountRef / creditorAccountRef	Referencias opacas de cuentas; acceso limitado según finalidad.
debitPostingRef / creditPostingRef	Referencias de contabilización verificadas.
aggregateVersion / completedAt	Versión monotónica del pago / instante de finalización.

Entrega, orden y errores

Outbox transaccional. Estado y evento pendiente se guardan juntos en la base del productor. El publicador puede emitir un duplicado si pierde el acuse; los consumidores deben tolerarlo. Este patrón no vuelve atómica una llamada al core: esa incertidumbre se trata con referencia monetaria, consulta y conciliación.

Inbox del consumidor. Se registra eventId junto con el efecto local en una transacción. Si existe una llamada externa, se conserva un trabajo durable y una referencia idempotente; guardar un inbox antes de la llamada no garantiza su resultado.

Orden. Pagos particiona por paymentId y asientos por accountId. El orden no es global ni se supone entre temas. Una brecha de aggregateVersion suspende la proyección afectada y dispara recuperación desde la fuente. Nunca se calcula autorización de gasto a partir del orden de llegada de eventos.

Reintentos. Errores transitorios usan demora exponencial con variación y límite de intentos. Política inicial para consumidores: 1, 5, 30, 120 y 300 segundos. Los errores de esquema o permisos se apartan inmediatamente. Las llamadas monetarias siguen la política de la sección 10.

Cola de errores. Cada consumidor tiene un destino de mensajes fallidos, propietario y alerta. Se conservan metadatos mínimos y contenido cifrado con acceso restringido. Reenviar exige corregir la causa, comprobar idempotencia y dejar evidencia de quién lo inició.

Retención. Se proponen siete días en temas operativos. Los productores conservan eventos publicados al menos siete días para recuperar una réplica del broker; los consumidores mantienen deduplicación al menos durante la ventana máxima permitida de reenvío. Archivo y datos regulatorios siguen otra política aprobada. El broker no es el archivo contable. Si un consumidor queda fuera de la ventana, se reconstruye con una instantánea consistente y una posición de continuación.

14. Patrones y tecnologías elegidas

Patrón o tecnología	Aplicación concreta y motivo	Costo o límite
Strangler Fig	C04/C05 conservan contratos mientras C06 migra cuentas al nuevo core.	Requiere inventario de rutas heredadas y un período de coexistencia.
Capa anticorrupción	C07/C08 convierten identificadores, protocolos y errores del proveedor a contratos bancarios.	Traducciones y excepciones necesitan pruebas de contrato.
Outbox + consumidores idempotentes	C05/C03/C06 publican sus cambios sin doble escritura entre base y broker.	Duplicados posibles; implica retención y limpieza controlada.
Circuit breaker + aislamiento	Cada conector limita concurrencia, espera y reintentos por destino.	Abrir el circuito genera pendientes o rechazos técnicos; nunca confirma pagos.

Patrón o tecnología	Aplicación concreta y motivo	Costo o límite
Servicios: Java/Spring Boot	Implementación futura de contratos y procesos con transacciones locales y telemetría.	Selección de versión soportada y dimensionamiento durante implementación.
Apache Kafka + registro de esquemas	Distribución de eventos, particiones y reproceso controlado.	Requiere capacidad operativa y medir retrasos; no garantiza efectos únicos en cores.
PostgreSQL por propietario	Estado durable de órdenes, consentimientos, directorio e inbox/outbox.	Aislamiento de roles y respaldo por dominio; sin consultas cruzadas.
Saga	C05 coordina cargos, abonos y reversos entre cores con resultados verificables.	Hay estados intermedios y casos que requieren intervención.
CQRS	C04 usa una proyección para listas y resúmenes; el core decide fondos disponibles.	Consistencia eventual visible. No se adopta event sourcing del libro.
API Manager: WSO2 API Manager	Catálogo, políticas y planos de tráfico segregados para canales y terceros.	Requiere operación HA, actualizaciones y validar interoperabilidad del IdP.
Kubernetes + OpenTelemetry	Réplicas de servicios y telemetría homogénea.	No reemplazan recuperación de bases ni de los sistemas bancarios externos.

La selección prioriza contratos abiertos y portabilidad. Es una propuesta técnica para validar, sin recomendar compras ni atribuir certificaciones a productos.

Las versiones y licencias se fijan tras pruebas de integración y soporte.

15. Identidad, acceso y controles de seguridad

Para terceros confidenciales se propone FAPI 2.0 Security Profile, con flujo de código, PKCE, PAR y tokens vinculados al emisor mediante mTLS. La conformidad requiere verificar el perfil completo, no solo activar OAuth. Los canales nativos utilizan el flujo apropiado para clientes públicos; no se les atribuye automáticamente conformidad FAPI. OAuth Security BCP guía la configuración.

Límite o componente	Control aplicado	Evidencia verificable
Internet a C01	WAF, TLS, cuotas por cliente, límites de tamaño y validación de contrato.	Pruebas de abuso, políticas y solicitudes bloqueadas.
Cliente a IdP	OIDC, MFA y refuerzo según operación. Web con BFF y cookies seguras; móvil con flujo nativo y PKCE.	Sesión, nivel de autenticación y pruebas de redirección.
Tercero a APIs	Registro del tercero, autenticación propia, consentimiento vinculado a titular, cuentas, alcance y vigencia.	Certificado, consentId y autorización efectiva de cada petición.
C03 y servicios de dominio	Permisos por objeto y acción; RBAC para roles y atributos de cuenta, canal, importe y consentimiento.	Negativas de acceso cruzado entre titulares y pruebas de revocación.
Servicio a servicio	Identidad de proceso, mTLS, audiencia y permisos mínimos; no propagar tokens de usuario indiscriminadamente.	Políticas de red y pruebas de identidad incorrecta.
C07/C08 hacia cores	Credenciales técnicas en bóveda, permisos por operación y control de autoridad vigente.	Rotación, acceso auditado y prueba de bloqueo de escritor antiguo.
Datos y claves	Cifrado en tránsito y reposo; claves protegidas por KMS/HSM y rotación con recuperación probada.	Inventario, bitácoras y restauración con claves del sitio alternativo.
Operadores / C17	SSO corporativo, MFA, acceso temporal privilegiado y doble aprobación de ajustes.	Quién solicitó/aprobó, motivo, alcance y asientos afectados.

Consentimiento durante una operación

C03 es la autoridad del consentimiento. Para consultas de terceros se verifica su estado actual; si no puede verificarse, se deniega. Una caché de tokens no basta para demostrar vigencia. Antes de enviar un cargo, C05 vuelve a validar la autorización y conserva su versión e instante. Una revocación posterior a ese punto bloquea nuevos usos, pero no equivale a deshacer una instrucción ya ejecutada; la cancelación sigue el estado y las reglas de pagos.

La auditoría registra actor, cliente técnico, recurso, decisión, versión de política y correlationId. Los registros excluyen tokens, secretos, números completos de cuenta y datos personales. La seudonimización reduce exposición, pero los datos vinculables siguen tratándose como personales.

16. Protección de datos y cumplimiento en Ecuador

La LOPDP contempla bases de licitud, principios de tratamiento, derechos y medidas de protección. Se diseña un tratamiento documentado por finalidad: ejecución contractual de operaciones, obligaciones aplicables y consentimiento cuando corresponda. No se utiliza el consentimiento como fundamento universal de toda actividad bancaria.

Necesidad	Implementación en esta arquitectura	Propietario y evidencia
Finalidad y minimización	Clasificar campos de APIs/eventos y limitar cada consumidor a lo necesario. Riesgos no recibe credenciales ni expedientes completos.	DPD y dueños de datos: inventario de tratamientos y contratos.
Información y consentimiento	C03 conserva finalidad, versión informativa, alcance, prueba de aprobación y revocación.	Canales / Identidad: recorrido del titular y historial.
Derechos del titular	Canal de solicitudes autenticadas y gestión de búsqueda por referencia global. Rectificación en la fuente y propagación a copias.	Atención al cliente + DPD: expediente y seguimiento de plazos.
Retención y eliminación	Calendario por tipo de dato y finalidad; bloqueo por obligación de conservación. Copias restauradas reaplican las exclusiones vigentes.	Jurídico / Datos: política y evidencia de ejecución.
Proveedores y ubicaciones	Inventariar quién trata qué datos, dónde y bajo qué contrato; evaluar encargos, destinatarios y transferencias según su naturaleza.	Compras / Jurídico / DPD: evaluación y contratos.
Alto riesgo y antifraude	Evaluar impacto antes de activar tratamientos; revisión humana de casos y trazabilidad de decisiones. Evaluar normativa de IA si se incorporan modelos.	Fraude / DPD: evaluación, modelos y controles aprobados.

Necesidad	Implementación en esta arquitectura	Propietario y evidencia
Incidentes	SOC conserva evidencia, delimita titulares afectados y activa coordinación con DPD y Cumplimiento.	Seguridad: cronología, alcance, decisiones y notificaciones.

Actualización normativa identificada

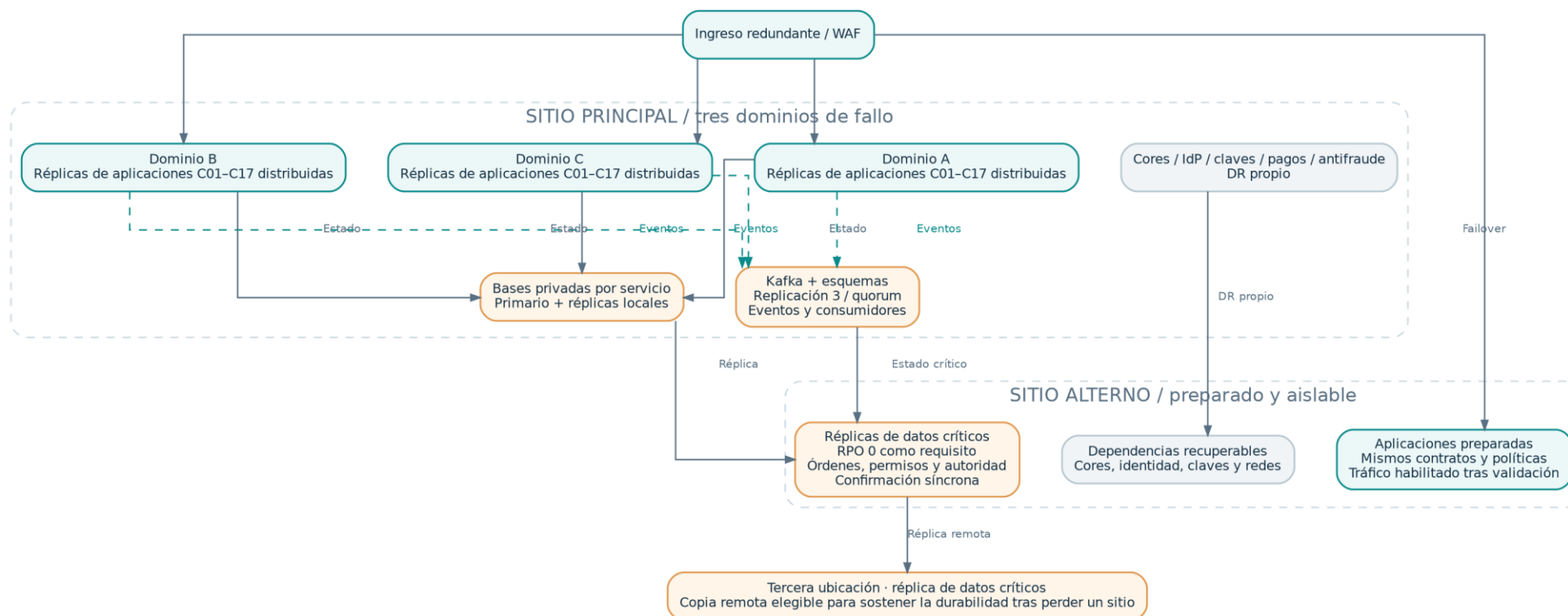
El Registro Oficial del 22 de mayo de 2026 reforma el primer inciso del artículo 43 de la LOPDP: contempla notificación a la autoridad de datos, al regulador competente y al CSIRT correspondiente, tan pronto como sea posible y, bajo sus condiciones, a más tardar en el término de cinco días desde que se tuvo constancia. El procedimiento no debe reducirse a copiar un plazo genérico de 72 horas de otra jurisdicción.

La SPDP publica normativa de transferencias 2026-0004-R y una norma técnica de notificaciones 2026-0040-R, además de reglas sobre gran escala y otros tratamientos. Se exige validar texto, vigencia y aplicabilidad de estas disposiciones al cerrar el procedimiento. El texto base de 2021 se consulta junto con sus reformas, no como compilación exhaustiva vigente.

La Superintendencia de Bancos documenta requisitos de riesgo operativo, continuidad y servicios críticos, incluida disponibilidad de 99,99% en su actualización de 2023. Cumplimiento debe contrastar la codificación vigente y la aplicabilidad exacta al banco. Este diseño aporta controles y evidencias; no constituye una certificación de cumplimiento ni fija plazos universales de conservación.

17. Alta disponibilidad y despliegue

La integración se ubica cerca de los cores, con sitio principal redundante, sitio alternativo preparado y tercera ubicación de réplica crítica. Este diagrama de despliegue complementa C4.



Los servicios sin estado se distribuyen entre tres dominios de fallo, con capacidad N+1, límites de concurrencia y sondas de preparación. Kafka utiliza replicación 3, confirmación de réplicas suficientes y elección de líder segura. Cada base tiene un único primario de escritura y réplicas con mecanismo de cuórum y exclusión. La replicación y el failover de los cores se verifican por separado con sus propietarios.

Órdenes, idempotencia, autoridad y consentimientos se confirman tras persistir en el primario y al menos una réplica remota elegible. La tercera ubicación permite restablecer esa condición tras perder un sitio. La promoción requiere cuórum, exclusión y posición de log verificada. Sin confirmación remota, se detienen escrituras críticas. Proyecciones y telemetría admiten réplica asíncrona; la latencia entre sitios se prueba.

18. Recuperación y procedimiento operativo

RTO significa tiempo objetivo de recuperación y RPO pérdida máxima de datos tolerada. Los valores siguientes son requisitos de diseño por validar; no se deducen de utilizar Kubernetes o un servicio administrado.

Elemento	Fallo local: RTO / RPO	Pérdida de sitio: RTO / RPO
APIs y procesos	≤ 60 s / sin estado local	≤ 5 min / reconstrucción desde estado durable.
D05 y registros críticos de C07/C08/C09	≤ 60 s / 0 de operaciones confirmadas	≤ 15 min / 0, condicionado a réplica síncrona efectiva; incluye referencias e idempotencia.
D03 permisos y D06 autoridad	≤ 60 s / 0 de cambios confirmados	≤ 15 min / 0; no habilitar escrituras con copias antiguas.
Cores y plataforma de pagos	Objetivo a homologar con proveedores	Habilitación monetaria ≤ 30 min; RPO 0 para asientos confirmados como requisito a demostrar.
Eventos operativos	≤ 60 s / 0 dentro del cuórum	≤ 15 min / ≤ 60 s, reconstruibles desde outbox y fuentes retenidas.
Proyecciones y analítica	≤ 5 min / ≤ 5 s	≤ 60 min / ≤ 15 min; se informa la frescura.

Secuencia de recuperación

1. Declarar incidente, limitar tráfico y suspender despachos monetarios. Registrar el último estado confiable y los pagos en curso.
2. Aislar el sitio fallido y probar exclusión de sus escritores. Sin exclusión verificable, no promover primarios monetarios.
3. Recuperar red, DNS, certificados, HSM/bóveda, IdP, bases y autoridad. Verificar posiciones de réplica y restablecer confirmación durable entre dos ubicaciones antes de escribir.
4. Recuperar cores y conectores, con la durabilidad monetaria exigida. Conciliar órdenes contra asientos, referencias de red y consentimientos; no reenviar automáticamente órdenes UNKNOWN.
5. Recuperar broker y consumidores. Reponer la ventana faltante desde fuentes retenidas con los mismos eventId. Verificar duplicados y secuencias.
6. Ejecutar sondas de consulta y operaciones sintéticas controladas. Habilitar consultas y luego pagos por cohortes, con observación intensiva.

7. Documentar pérdidas, retrasos y discrepancias; regresar al sitio principal mediante procedimiento planificado y nueva exclusión de escritura.

Los respaldos son cifrados, inmutables y separados de las credenciales operativas. Una copia se conserva aislada del dominio de administración principal. Se realizan restauraciones y simulacros trimestrales como frecuencia inicial propuesta.

Riesgo residual explícito. Un 99,99% mensual permite aproximadamente 4,32 minutos de caída en un mes de 30 días. El RTO de desastre de 30 minutos excede ese presupuesto. El diseño detallado debe reducir el tiempo del recorrido crítico o tratar formalmente la brecha, sin excluir desastres del indicador. Si un core no garantiza RPO 0, la cohorte no se declara apta hasta acordar una solución técnica y de negocio.

19. Migración gradual y cambio de autoridad

Fase	Trabajo principal	Puerta de salida
0. Descubrimiento	Inventariar interfaces, lotes, clientes, productos, datos y ventanas; verificar deduplicación y recuperación.	Contratos, propietarios y restricciones aprobados; capacidad monetaria del core demostrada.
1. Encapsular	Publicar C04/C05 sobre el core tradicional mediante C06/C07. Introducir observabilidad y conciliación.	Recorrido completo probado y semántica de errores estable.
2. Validar lectura	Sincronizar una cohorte al digital en modo de validación; comparar saldos, movimientos, bloqueos y condiciones.	Cero diferencias monetarias sin explicación; cobertura de casos límite.
3. Piloto	Cuentas internas o voluntarias de bajo riesgo; restringir productos y montos.	Operaciones, reversos y DR validados; sin incidentes críticos abiertos.
4. Ampliar	Cohortes orientativas de 1%, 5%, 20%, 50% y 100%, ajustadas a riesgo y soporte.	Cada cohorte supera conciliación, objetivos operativos y un ciclo de cierre.
5. Retirar	Cerrar escrituras heredadas y conservar histórico según política; retirar interfaces sin consumidores.	Dependencias verificadas, archivo recuperable y aprobación de responsables.

Corte de una cohorte

El coordinador de C06 marca QUIESCING, bloquea instrucciones nuevas y solicita drenaje de pagos en curso. Se suspenden también lotes, sucursales y otras entradas que puedan escribir en esas cuentas. No basta con cambiar el Gateway.

Se toma una instantánea con punto de corte, se aplican los deltas pendientes y se concilian saldo contable, saldo disponible, retenciones, intereses y movimientos. Se cierran las escrituras del origen, se incrementa la versión de autoridad y se habilita exclusivamente el destino. Cada adaptador rechaza versiones obsoletas. Después se reabre tráfico y se vigilan discrepancias y latencia.

Retroceso seguro

Antes de la primera escritura en el nuevo core, se puede abortar el corte y restablecer la autoridad anterior tras comprobar que no hubo efectos. Después de nuevas contabilizaciones, volver exige detener tráfico, conciliar, trasladar movimientos por un procedimiento aprobado y ejecutar otro cambio de autoridad. Un cambio de bandera no constituye un retroceso financiero.

Se pausa el avance por cualquier duplicado monetario, diferencia de saldo no explicada, fallo de permisos, incapacidad de reconstruir una operación o deterioro del objetivo acordado. El calendario se define después del descubrimiento; los porcentajes son una estrategia de expansión, no una estimación de duración.

20. Gobierno y principios de diseño

Ámbito	Responsable de decisión	Regla y evidencia
Dominio y contrato	Dueño de producto + equipo del servicio	Catálogo con finalidad, propietario, datos, consumidores, SLA/SLO y clasificación.
Diseño transversal	Arquitectura de integración	Revisión de límites, BIAN, dependencias y decisiones documentadas con alternativas y costos.
Seguridad y privacidad	Seguridad + DPD + Cumplimiento	Modelo de amenazas, autorización, evaluación de impacto y evidencia de pruebas.
Operación	SRE + dueño del servicio	Manual, paneles, alertas, guardia y recuperación ensayada antes de publicar.
Cambios de contrato	Productor + consumidores afectados	Análisis de compatibilidad; pruebas de consumidor y período de convivencia.
Cambios monetarios	Pagos + Contabilidad + Operaciones	Referencias, segregación de funciones, conciliación y aprobación de ajustes.

El ciclo de una API o evento recorre propuesta, revisión, publicación en entorno de pruebas, validación de consumidores, activación, observación y retiro. El catálogo registra también temas, esquemas y dependencias. Se propone aviso mínimo de seis meses para retirar una versión externa, sujeto a contratos y obligaciones del banco.

Principios aplicados a componentes

Responsabilidad única. C06 decide ubicación; C05 administra el pago; los cores contabilizan. C01 aplica políticas de acceso técnico y C02 compone respuestas, sin decidir reversos o rutas contables.

Segregación de interfaces. Consultar saldo, ejecutar un movimiento y verificar su resultado son capacidades diferentes. Un consumidor de consulta no recibe credenciales para contabilizar.

Inversión de dependencias. El motor de Pagos depende de puertos de autorización, fraude y contabilización. Las implementaciones hacia C07/C08 pueden evolucionar preservando el contrato y las pruebas.

Cohesión y bajo acoplamiento. Cada servicio posee sus datos y hechos. Se comparte nomenclatura y esquemas públicos, no entidades internas de persistencia ni librerías que obliguen a desplegar todos los equipos a la vez.

Evolución independiente. La iniciación y la orquestación se mantienen inicialmente dentro de C05 por cohesión del ciclo de pago. Su separación futura requiere una necesidad operativa demostrada, manteniendo propiedad inequívoca del estado y contrato entre ambas.

21. Observabilidad, pruebas y aceptación

OpenTelemetry registra trazas, métricas y registros correlacionados; propaga traceparent por HTTP y metadatos de mensajería. El identificador de negocio paymentId persiste aunque una operación atravesase varias trazas o se reanude después de una caída.

Señal	Umbral inicial y acción	Responsable
Error técnico y latencia por recorrido	Alertar por consumo acelerado del presupuesto de disponibilidad; separar por core y canal.	SRE + dueño del recorrido.
Pagos UNKNOWN / puente pendiente	Alerta al superar 60 s; caso operativo a los 5 min.	Pagos + Operaciones.
Edad outbox, demora	Aviso a 30 s; degradación controlada si supera 5 min o capacidad segura.	Plataforma + productor/consumidor.
Mensajes fallidos	Cada mensaje abre señal al propietario; agrupar incidentes por causa.	Equipo consumidor.
Conciliación	Diferencia monetaria no explicada detiene ampliación de cohorte.	Contabilidad + Plataforma core.

Señal	Umbral inicial y acción	Responsable
Replicación y autoridad	Pérdida de confirmación crítica o versiones discrepantes bloquea escrituras afectadas.	Bases de datos + Plataforma core.

Los paneles operativos muestran referencias opacas y agregados. La auditoría monetaria y de autorización es completa según política; las trazas pueden muestrearse y nunca sustituyen la evidencia de negocio. El SOC recibe eventos de seguridad con acceso segregado.

Pruebas exigidas antes de producción

- Repetir la misma orden en paralelo y tras reiniciar un proceso: debe existir un solo efecto por paso monetario.
- Perder la respuesta después del cargo: debe aparecer UNKNOWN y resolverse mediante consulta, sin segundo cargo.
- Rechazar un abono: verificar reversión autorizada y conciliación de cuentas puente; perder su respuesta y comprobar el mismo tratamiento de incertidumbre.
- Revocar consentimiento, cambiar el titular o manipular una cuenta: el acceso indebido debe ser rechazado en el servicio propietario.
- Interrumpir broker, IdP, antifraude, bases y conectividad: comprobar cada modo de degradación y recuperación.
- Cambiar de core mientras hay órdenes y lotes en curso: demostrar que no existe doble escritor, incluido un proceso antiguo.
- Restaurar el sitio alternativo y reproducir eventos: verificar referencias, deduplicación, saldos y tiempos RTO/RPO medidos.
- Ejecutar carga representativa, ráfagas y cierre diario: comprobar latencias, límites de cada core y aislamiento de consumidores lentos.

Estas son condiciones de aceptación de una implementación futura. El presente entregable no afirma haber ejecutado pruebas de una infraestructura bancaria.

22. Cobertura del ejercicio y decisiones pendientes

Tarea del enunciado	Evidencia en el documento
1. Arquitectura de alto nivel y BIAN	Secciones 03-08: C1, dos vistas C2, dos C3 y matriz semántica.
2. Patrones y tecnologías justificados	Secciones 09-14: saga, contratos, outbox, adaptadores y tecnología.

Tarea del enunciado	Evidencia en el documento
3. Seguridad y protección de datos	Secciones 15-16: controles ubicados y aplicación del supuesto Ecuador.
4. HA y recuperación ante desastres	Secciones 17-18: topología, réplica, objetivos y procedimiento.
5. Integración multicore	Secciones 07-10 y 19: autoridad, transferencias y corte.
6. Identidad y acceso	Secciones 04 y 15: IdP, permisos por recurso, terceros y procesos.
7. APIs internas/externas y mensajería	Secciones 11-13: contratos, eventos, esquemas, orden y errores.
8. Gobierno de APIs y microservicios	Sección 20: responsables, ciclo de vida y principios de componentes.
9. Migración gradual	Sección 19: etapas, puertas de salida y límites del retroceso.
10. Observabilidad y trazabilidad	Sección 21: señales, correlación, responsables y aceptación.

Decisiones que requieren información del banco

Capacidades reales del core. Deduplicación, consulta de resultados, bloqueo de escritura, retenciones y replicación determinan si la automatización propuesta es viable. El diseño identifica estos contratos como condiciones de entrada.

Impacto y continuidad. La latencia entre sitios, el RTO de sistemas externos y el objetivo de disponibilidad deben verificarse conjuntamente. No se atribuye disponibilidad de extremo a extremo a partir de la disponibilidad aislada de un componente.

Normativa y contratos. La jurisdicción es un supuesto. La entidad debe completar el análisis con su regulación específica, productos, proveedores, acuerdos con terceros y plazos de retención. Los estándares técnicos no se presentan como obligaciones legales locales por defecto.

Prioridad de negocio. Cohortes, montos, productos y ventanas se acuerdan con Operaciones y Riesgos. Se conserva el historial del cliente y la trazabilidad de cada cuenta durante todo el período de convivencia.